



Security Assessment



Item 17 Internal Report

August 2026

Prepared for ether.fi



Disclaimer

This document is intended for **internal** use only.

Initial Commit Hash	Final Commit Hash
18f224a108	2aed606ac4

Protocol Scope

- src/across/AcrossSwapModule.sol
- src/cashback-dispatcher/CashbackDispatcher.sol
- src/data-provider/EtherFiDataProvider.sol
- src/debt-manager/DebtManagerAdmin.sol
- src/debt-manager/DebtManagerStorageContract.sol
- src/enso/EnsoSwapModule.sol
- src/modules/cash/CashModuleCore.sol
- src/modules/cash/CashModuleSetters.sol
- src/modules/cash/CashModuleStorageContract.sol
- src/modules/etherfi/EtherFiLiquidModule.sol
- src/modules/etherfi/LiquidUSDLiquidifierOP.sol
- src/modules/hype/BeHYPEStakeModule.sol
- src/modules/lend-gateway/LendGateway.sol
- src/modules/midas/MidasModule.sol
- src/modules/stargate/StargateModule.sol
- src/modules/wormhole/WormholeModule.sol
- src/oracle/PriceProvider.sol
- src/oracle/PriceProviderV2.sol
- src/role-registry/RoleRegistry.sol
- src/settlement-dispatcher/SettlementDispatcherV2.sol
- src/stock-withdraw/StockUnwrapper.sol
- src/stock-withdraw/StockWithdrawModule.sol
- src/top-up/TopUpDest.sol
- src/top-up/TopUpFactory.sol
- src/trading-safe/TradingLens.sol
- src/trading-safe/TradingSafeFactory.sol
- src/utils/UpgradeableProxy.sol

Low Severity Issues

L-01: The operating-timelock role can install delegatecall code in TopUpFactory

Severity: Low	Impact: Medium	Likelihood: Low
Files: src/top-up/TopUpFactory.sol	Status: Pending	

Description:

The PR moves `setTokenConfig` from the `RoleRegistry` owner to `ADMIN_TIMELOCK_ROLE`. A token configuration includes `bridgeAdapter`, and bridge subsequently executes that adapter with delegatecall. Consequently, the operating-timelock tier can select code that executes in the `TopUpFactory` proxy's storage context. Once an authorized bridger invokes the configured route, a malicious adapter can overwrite proxy/factory storage or transfer assets held by the factory, bypassing the intended owner-only upgrade boundary.

The trigger also requires a `TOPUP_FACTORY_BRIDGER_ROLE` call, and `whenNotPaused` can block `bridge`.

Recommendations:

Treat selection of delegatecall targets as an upgrade and gate `bridgeAdapter` changes with the `RoleRegistry` owner.

Customer Response:

Acknowledged

Informational Issues

I-01. The fast global admin can replace live Midas vault destinations

Description: `addMidasVaults` overwrites the vault pair for an already-supported Midas token, and deposit/withdraw execution resolves the vault from live configuration. A compromised or malicious `ADMIN_ROLE` holder can therefore replace a redemption vault before a separately authorized Safe withdrawal executes. The Safe then approves and calls the replacement vault (or a presigned approval could also be used). In the asynchronous redemption path, the module does not verify receipt of the eventual redemption output in the same transaction.

Recommendation: Put vault additions/replacements behind `ADMIN_TIMELOCK_ROLE`, preventing silent replacement

Customer's response: Fixed in [PR-299](#)

Fix review: Fix confirmed

I-02. Fast collateral-risk changes can immediately affect legacy Safe health

Description: The consolidated `ADMIN_ROLE` can immediately lower LTV/liquidation parameters and can remove an in-use non-borrow collateral token without checking whether legacy Safes still hold it. Removing the token from supported-collateral enumeration, or lowering its parameters, can reduce the collateral value counted by health calculations and expose affected positions to liquidation without an on-chain grace period. Additionally, such operations may cause bad debt.

Recommendation: Timelock risk-reducing changes that affect existing positions, or apply them through a delayed two-step process. Prevent removal while relevant positions remain open.

Customer's response: Acknowledged

I-03. The fast admin can replace a live teller used by a pending liquid-asset bridge

Description: `addLiquidAssets` can overwrite the live teller for an existing asset. A bridge request stores the asset and bridge terms but not the teller; execution reads the teller later from current configuration. Although the replacement must return the expected asset from `vault()`, a malicious contract can satisfy that check. A compromised fast admin could therefore route a pending owner-authorized bridge through a malicious or non-functional teller.

Recommendation: Put teller replacement behind `ADMIN_TIMELOCK_ROLE`

Customer's response: Fixed in [PR-299](#)

Fix review: Fix confirmed

I-04. Oracle configuration loses a faster incident-response path

Description: The PR moves oracle configuration/removal and `EtherFiDataProvider.setPriceProvider` to `ADMIN_TIMELOCK_ROLE`. Under the intended deployment, a faulty or compromised feed cannot be replaced through these setters until the operating timelock executes. Pausing the price-provider proxy does not act as a feed circuit breaker because `price()` has no pause check.

Recommendation: Consider adding a secondary oracle, which the fast admin can instantly switch to. Alternatively, consider acknowledging this issue.

Customer's response: Fixed in [PR-299](#)

Fix review: Fix confirmed

I-05. The fast admin can redirect provider-fee revenue for pending withdrawals in StockWithdrawModule

Description: The fee rate is snapshotted per request, but `feeReceiver` is read live at execution. The PR assigns the setter to global `ADMIN_ROLE`. A compromised fast admin can therefore redirect provider-fee revenue from pending withdrawals to another nonzero address. Per the Pr's description, fund destinations should be guarded by `ADMIN_TIMELOCK_ROLE`

Recommendation: Put fee receiver setter behind `ADMIN_TIMELOCK_ROLE`

Customer's response: Fixed in [PR-299](#)

Fix review: Fix confirmed

I-06. One operating-timelock role controls both module-withdrawal allowlists

Description: The same `ADMIN_TIMELOCK_ROLE` can globally whitelist an address as a module and authorize it in `whitelistedModulesCanRequestWithdraw`. An address present in both sets can request a withdrawal for any recognized EtherFi Safe without a Safe-owner signature; the recipient is fixed to the calling module. After the configured withdrawal delay, the module can process the request and receive the tokens.

Note: Before the PR, two different roles were used – `DATA_PROVIDER_ADMIN_ROLE` and `CASH_MODULE_CONTROLLER_ROLE`, which had the same owner.

Recommendation: Consider separating the two roles with different ownership.

Customer's response: Acknowledged

I-07. Fast-admin roles can replace core protocol dependencies without the governance timelock

Description: Several setters that replace core protocol dependencies are authorized through operational admin roles rather than `onlyRoleRegistryOwner`:

- `EtherFiDataProvider.setCashModule`
- `EtherFiDataProvider.setCashLens`
- `EtherFiDataProvider.setPriceProvider`
- `EtherFiDataProvider.setHookAddress`
- `EtherFiDataProvider.setEtherFiSafeFactory`
- `CashModuleSetters.setSettlementDispatcher`
- `CashModuleSetters.setLendGateway`
- `CashbackDispatcher.setPriceProvider`
- `TradingSafeFactory.setTradingLens`

Recommendation: Consider using `onlyRoleRegistryOwner` for those setters

Customer's response: Fixed in [PR-299](#)

Fix review: Fix confirmed

I-08. Re-gated functions retain stale NatSpec and unused `OnlyAdmin` error declarations, breaking off-chain integrations

Description: After delegating admin checks to `RoleRegistry`, numerous contracts retain unreachable `OnlyAdmin` error declarations and out-of-date `@custom:throws` tags (e.g., documenting `OnlyCashModuleController` or older proxy upgrade roles). Because the newly integrated role registry emits different errors, ABI consumers, off-chain simulations, and monitoring runbooks relying on the old selectors will silently misclassify rejections.

Code Locations:

- AcrossSwapModule.sol#L127-L129
- EtherFiDataProvider.sol#L87-L89
- EnsoSwapModule.sol#L108-L110
- CashModuleSetters.sol#L66-L75
- CashModuleSetters.sol#L100-L113
- CashModuleSetters.sol#L147-L158
- CashModuleStorageContract.sol#L114-L116
- EtherFiLiquidModule.sol:549-556
- EtherFiLiquidModule.sol:579-584
- BeHYPEStakeModule.sol:96-108
- StargateModule.sol:171-181
- WormholeModule.sol:155-166
- StockWithdrawModule.sol:200-201
- StockWithdrawModule.sol#L285-L341
- StockWithdrawModule.sol:779-788
- TopUpDest.sol:139-147
- TopUpFactory.sol#L448-L454
- TradingLens.sol:59-60
- TradingLens.sol#L99-L118

Recommendation: Remove unused error declarations from module contracts. Update all NatSpec and `@custom:throws` tags to reflect the correct `RoleRegistry.OnlyAdmin()` or `RoleRegistry.OnlyAdminTimelock()` errors, ensuring ABI compatibility.

Customer's response: Fixed in [PR-299](#)

Fix review: Fix confirmed

Disclaimer

Even though we hope this information is helpful, we provide no warranty of any kind, explicit or implied. The contents of this report should not be construed as a complete guarantee that the contract is secure in all dimensions. In no event shall Certora or any of its employees be liable for any claim, damages, or other liability, whether in an action of contract, tort, or otherwise, arising from, out of, or in connection with the results reported here.

About Certora

Certora is a Web3 security company that provides industry-leading formal verification tools and smart contract audits. Certora's flagship security product, Certora Prover, is a unique SaaS product that automatically locates even the most rare & hard-to-find bugs on your smart contracts or mathematically proves their absence. The Certora Prover plugs into your standard deployment pipeline. It is helpful for smart contract developers and security researchers during auditing and bug bounties.

Certora also provides services such as auditing, formal verification projects, and incident response.